

Information Security Policy

Organization: OutFront Data — a financial-insights software product operated by Makers' House LLC

Policy owner: Sean Austin (Founder) — seanaustin1@gmail.com

Effective date: 2026-06-15

Version: 1.0

Review cadence: At least annually, and after any material change to systems or a security incident.

1. Purpose & Scope

This policy documents how OutFront Data identifies, mitigates, and monitors information-security risks across the systems and data we operate. It applies to all personnel, contractors, code, infrastructure, and third-party services involved in delivering the product. It is operationalized through the controls described below, which are in effect today and reviewed on the cadence in §14.

2. Roles & Responsibilities

- The **Policy Owner** is accountable for the security program: maintaining this policy, granting/revoking access, responding to incidents, and conducting the periodic review.
- All personnel are responsible for following this policy, using strong unique credentials with MFA, and reporting suspected security issues to the Policy Owner without delay.

3. Data We Handle & Classification

Class	Examples	Handling
Highly sensitive	End-customer bank & card transaction data (via Plaid), Plaid access tokens	Encrypted at rest; access restricted to production systems and the Policy Owner; never logged in plaintext
Sensitive	Customer business financial metrics, categorized spend, account metadata	Stored in access-controlled database; tenant-isolated
Personal	Account holder name/email, business contact info	Minimized; access-controlled
Internal	Application config, non-secret settings	Standard access controls

We do **not** store end-users' bank login credentials — those are held by Plaid. We obtain bank data on a **read-only** basis. We collect the minimum data necessary to provide the service.

4. Access Control & Authentication

- End-user authentication and identity are handled by **Clerk**, with **role-based access control** (Operator, Manager, Consultant, Investor) enforcing least privilege per tenant.
- Administrative access to production infrastructure (Vercel, Supabase, Clerk, Plaid, GitHub) is limited to the Policy Owner and protected with **multi-factor authentication** and strong, unique passwords stored in a password manager.
- Access is granted on a least-privilege basis and **revoked promptly** when a person no longer requires it (offboarding) or on suspected compromise.

5. Encryption

- **At rest:** Plaid access tokens are encrypted using **AES-256-GCM** with a dedicated 32-byte key managed as a secret (`ENCRYPTION_KEY`), never committed to source control. The primary datastore (Supabase Postgres) provides encryption at rest at the platform level.
- **In transit:** All connections to the application and between services use **TLS (HTTPS)**. The production domain is served over HTTPS with automatically managed certificates.

6. Secrets & Key Management

- All credentials, API keys, and encryption keys are stored as **environment variables / secrets** in the hosting platform (Vercel) and local `.env` files that are **excluded from source control** (`.gitignore`).
- Secrets are **not** logged, embedded in code, or shared over insecure channels.
- Production and development environments use **separate keys**. Secrets are **rotated** on personnel offboarding or any suspected exposure.

7. Application & Code Security

- Source code is stored in a **private GitHub repository**. Changes are reviewed before merging to the main branch.
- Production builds are deployed through **Vercel** with an automated build pipeline; the application is built with a current, supported framework (Next.js) and maintained dependencies.
- Dependencies are kept up to date, and security advisories affecting our stack are evaluated and patched promptly.
- Multi-tenant data isolation is enforced in application logic so a tenant can only access its own records.

8. Third-Party Vendors / Subprocessors

We rely on established providers, each of which maintains its own industry-standard security program (e.g., SOC 2). We limit data shared to what each service needs:

Subprocessor	Purpose	Data
Plaid	Bank/transaction data aggregation (read-only)	Bank connection, transactions
Supabase	Application database (Postgres)	Transaction & app data
Clerk	Authentication & identity	User identity, auth
Vercel	Application hosting	App traffic
Inngest	Background job processing	Job payloads
Resend	Transactional email	Email address, message content
Anthropic	AI extraction of user-uploaded statements	Only documents the user uploads
GitHub	Source code hosting (private)	Source code
Dwolla *(planned)*	ACH money movement (not yet enabled)	Account/transfer data

New subprocessors are evaluated for security posture before adoption.

9. Logging, Monitoring & Risk Identification

- Application, infrastructure, and authentication events are logged via platform tooling (**Vercel** runtime/deploy logs, **Supabase** logs, **Clerk** authentication logs, **Inngest** job logs).
- Logs are reviewed when investigating errors or anomalies; sensitive values (tokens, secrets, full account data) are excluded from logs.
- The Policy Owner periodically reviews access, dependency advisories, and provider status to **identify** emerging risks.

10. Risk Management Process

1. **Identify** — review data flows, access, dependencies, and subprocessors for risks (at least annually and on material change).
2. **Assess** — rate each risk by likelihood and impact, prioritizing risks to highly sensitive data.
3. **Mitigate** — apply or strengthen the controls in this policy; track remediation to closure.
4. **Monitor** — re-check via logging/review (§9) and confirm mitigations remain effective.

11. Incident Response

1. **Detect & report** — anyone who suspects an incident notifies the Policy Owner immediately.
2. **Contain** — isolate affected systems, rotate exposed credentials/keys, and revoke compromised access.
3. **Assess** — determine scope, data involved, and root cause.

4. **Notify** — notify affected parties and **Plaid** (and any other relevant providers/authorities) within the timeframes required by contract and applicable law.
5. **Recover & learn** — restore service, document the incident, and update controls to prevent recurrence.

12. Data Retention, Backup & Continuity

- Production data is hosted on **Supabase**, which provides managed, encrypted backups, enabling recovery in the event of data loss.
- Data is retained only as long as needed to provide the service or as required by law; end-customers may disconnect a bank connection, after which we stop syncing new data and remove associated access tokens.

13. Personnel & Security Awareness

- All personnel review this policy on joining and at each annual review.
- Personnel use MFA, a password manager, kept-current devices with disk encryption, and follow least-privilege and secret-handling rules above.

14. Policy Governance & Review

This policy is reviewed and updated **at least annually**, and after any major system change or security incident. As the business scales and onboards external customers, the program will mature toward a formal framework (e.g., SOC 2) as customer and regulatory needs require.

Version	Date	Author	Notes
1.0	2026-06-15	Sean Austin	Initial policy